# SOP-IT-002 · Reading room and helper access: browser first, a token only if needed

SOP IT-002 | Status draft | Changed 2026-11-01 | For Members and stewards

**Department:** IT · **ID:** 002 · **Status:** draft (approved when tagged) · **Owner:** organisation administrator · **Last changed:** 2026-11-01

## Purpose

The steps a member follows to read an organisation's private repositories, and the steps for letting an AI helper read the same selected material, with the smallest credential that fits. The reasoning lives in proposal THEF 012 and in `my-template/org-onboarding/ACCESS-AND-PATS.md`; this is only the procedure.

## Scope

Any person given access to an organisation's private repositories, and their helper. Not for treasury keys, recovery codes or passwords.

## Roles

| Role | Does |
|---|---|
| Member | signs in, reads, asks for a helper if wanted |
| Administrator | invites, approves token requests, verifies as the member |
| Helper | reads only what it is granted; never receives a secret in chat |

## Steps: read as yourself

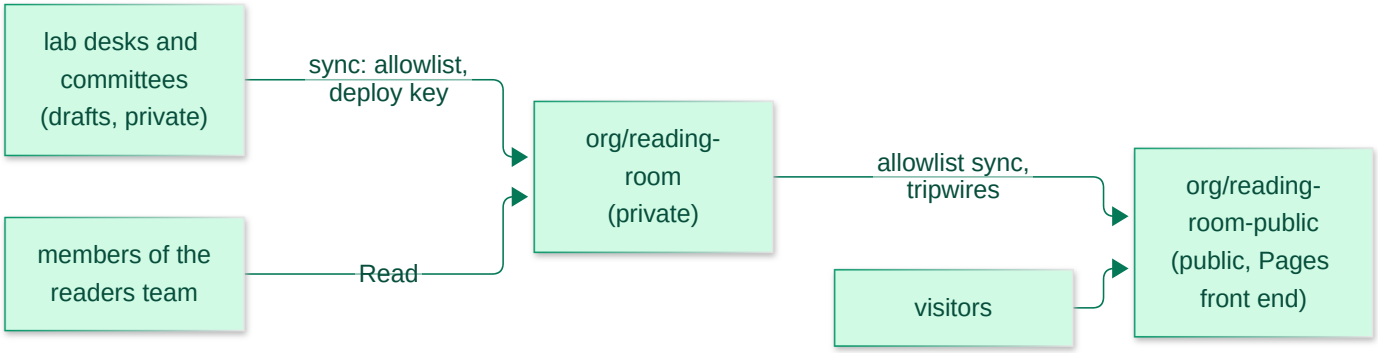
1. Sign in to GitHub with your own account and two-factor authentication on. *You should see:* your avatar top right.
2. Accept the organisation invitation (email or the bell icon). *You should see:* the organisation under your profile's Organizations.
3. Open the repository link you were given, then one README and its PDF under `pdf/`. *You should see:* the page, not a 404. A 404 on a private link means permission is absent: tell the administrator which account you are signed in as.
4. Reply where you already talk to the organisation, or open an Issue if your role allows.

## Steps: bring a helper, optionally

1. Ask whether the helper already has an approved GitHub connection that reaches the repository. *If yes:* stop here.
2. If a credential is required, create a **fine-grained personal access token** in your own account: resource owner = the organisation; only the repositories needed; **Contents: Read-only** (plus the metadata GitHub requires); a short expiry. *You should see:* the token once; copy it only into the helper's own credential store.
3. The administrator approves the request if the organisation requires approval. *You should see:* the token's status change from pending to active.
4. Ask the helper to read one named README and summarise it without changing anything. *You should see:* a correct summary and no commit.
5. Record owner, purpose, repositories, expiry and who can revoke, in the organisation's private onboarding notes. Never the token.
6. Revoke or rotate when the purpose ends, the role changes, a device is lost, or exposure is suspected.

## The reading-room route (organisation-owned)

A **reading room** is where an organisation's people read drafts that are not public yet, with a public room beside it for what is ready for visitors. Fill in your organisation's addresses once, then link this table from the organisation's `.github` README and its onboarding page.




The sync's rule and the tripwires are in SOP-OPS-003; the readers team and the base permission in SOP-GOV-002.

| Piece | What it is | Your organisation's address |
|---|---|---|
| Private room | `<org>/reading-room`: an **organisation-owned** private repository holding the drafts the organisation's people may read (proposals, procedures, decks). Its README is the index; PDFs sit beside the markdown | `https://github.com/<org>/reading-room` |
| Readers team | `<org>/<readers-team>` (for example `readers`), a closed team with **Read** on the private room and nothing else | `https://github.com/orgs/<org>/teams/<readers-team>` |
| Public room | `<org>/reading-room-public`: a public repository that receives **only allowlisted pages** from the private room, with a GitHub Pages front end in the house style | `https://<org>.github.io/reading-room-public/` |
| How drafts arrive | a sync workflow in the source (the `sync-public-allowlist.yml` shape: tripwire first, a deploy key per destination), never hand edits | the source repository's allowlist file |

Why organisation-owned: a personal private repository cannot give anyone read-only access (the 422 below), and Pages on a private repository publishes **publicly** on the free plan, so a members-only website is not available today. The private room's front end is therefore the repository itself (README index, PDFs, decks); the public room is the website. A members-only site (an access gate in front of a Pages build, or GitHub Enterprise) is the later option.

### ORG's reading room (filled in 2026-10-31, read again 2026-11-01)

| Piece | ORG's address | State on 2026-11-01 |
|---|---|---|
| Private room | https://github.com/Octagon-Religious-Research-Group-ORG/reading-room | **created**, private, merge commits only. README index; `proposals/`, `procedures/` and `decks/` shelves |
| Readers team | https://github.com/orgs/Octagon-Religious-Research-Group-ORG/teams/readers | **created**, closed, **Read** on `reading-room` and nothing else. Its only member is the steward who created it |
| Public room | https://github.com/Octagon-Religious-Research-Group-ORG/reading-room-public, served at https://octagon-religious-research-group-org.github.io/reading-room-public/ | **created**, Pages on from `main`; its front end is one `index.html` in emerald, no build step |

| | | |
|---|---|---|
| Procedures twin | https://github.com/Octagon-Religious-Research-Group-ORG/ops-standard-operating-procedures-public | **created**; README only until the first sync |
| How drafts arrive | the lab desk's `READING-ROOM-ALLOWLIST.txt` → `reading-room` (`READING_ROOM_DEPLOY_KEY`, in the lab desk); `reading-room`'s `PUBLIC-ALLOWLIST.txt` → `reading-room-public` (`READING_ROOM_PUBLIC_DEPLOY_KEY`); this repository's `PUBLIC-ALLOWLIST.txt` → the procedures twin (`SOP_PUBLIC_DEPLOY_KEY`) | **inert**: no deploy key exists yet. Each runs `scripts/allowlist-sync.sh`; the two public ones also run the public-lane tripwire (`scripts/scan-public-lane.sh`, SOP-OPS-003). Tripwire first, an ordinary commit, never a force-push |

**Base permission.** Since 2026-11-01 ORG's base member permission is **No permission** (SOP-GOV-002). All four of ORG's members are owners today, so nobody lost access; the `readers` team becomes the door for the next person who joins as a member. Adding a reader, on an officer's yes:

```
gh api -X PUT orgs/Octagon-Religious-Research-Group-ORG/teams/readers/memberships/<login>
```

### Steps: steward (once per organisation)

1. Create both rooms (an owner's action): `gh repo create <org>/reading-room --private` and `gh repo create <org>/reading-room-public --public`. *You should see:* both under the organisation's repositories.
2. Create the team and grant Read on the private room only:

   ```
   gh api -X POST orgs/<org>/teams -f name=<readers-team> -f privacy=closed
   gh api -X PUT orgs/<org>/teams/<readers-team>/repos/<org>/reading-room -f permission=pull
   ```

3. Add readers on an officer's yes: `gh api -X PUT orgs/<org>/teams/<readers-team>/memberships/<login>` (the same shape as SOP-GOV-001).
4. Give the public room a deletion-only ruleset (ORG's sync never force-pushes, and the ruleset keeps `main` from being deleted; SOP-OPS-002 legend) and turn on Pages from `main`.
5. Fill in the table above with the real addresses; link it from the organisation's `.github` README.

### Steps: reader

1. Accept the organisation invitation and the team, then open the private room's README. *You should see:* the index, not a 404.
2. Read in the browser, or open a PDF from `pdf/`. To bring a helper, follow *bring a helper* above, choosing only `reading-room` in the token's repository selection.

## Verification

The member opens the page from their own account; the helper's read test passes; the administrator can see the token under the organisation's personal access tokens with the expected scope.

## Troubleshooting

| Symptom | Likely cause | What to do |
|---|---|---|
| A read-only invitation to a personal (not organisation) private repository fails with 422 | GitHub offers no read-only collaborator on personal repositories | use the organisation-owned repository as the door; never grant write and call it read-only |
| The token works for public repositories only | approval pending | the administrator approves it |

| | | |
|---|---|---|
| The helper cannot reach a repository the member can | token's repository selection excludes it, or an outside-collaborator limitation | adjust selection, or move to organisation membership / an approved GitHub App |

## Related

- SOP-COM-001 *New to GitHub: your first hour* (where a newcomer starts), SOP-GOV-002 *GitHub collaboration*, SOP-OPS-003 *Private houses everything, public lanes witness*
- Proposal: THEF 012 *Your reading room, and how your helper joins you*
- `my-template/org-onboarding/ACCESS-AND-PATS.md`
- SOP-OPS-002 (a helper opens pull requests but does not merge; the legend), SOP-GOV-001 (the Board's room uses the same team shape)
- `my-template/workflow-templates/sync-public-allowlist.yml` (how drafts reach a room)

## Change log

| Date | Change | By |
|---|---|---|
| 2026-10-30 | Drafted from Littlebird's access draft and the Oct 30 verification | Alfred |
| 2026-10-31 | The generic reading-room route: an organisation-owned private room, a readers team with Read, a public room with a Pages front end, a fill-in address table | Alfred |
| 2026-11-01 | Lucid pass: Lucide icons, the route drawn in Mermaid; links to SOP-OPS-003 (the tripwires) and SOP-GOV-002 (teams, base permission none); new readers start at SOP-COM-001 | Alfred |
| 2026-11-01 | ORG's copy brought level with my-template: Lucide icons in emerald, Mermaid where a picture explains, ORG's own facts kept; ORG's room table read again: both rooms and the twin created, base permission none, syncs inert until their keys | Alfred |